

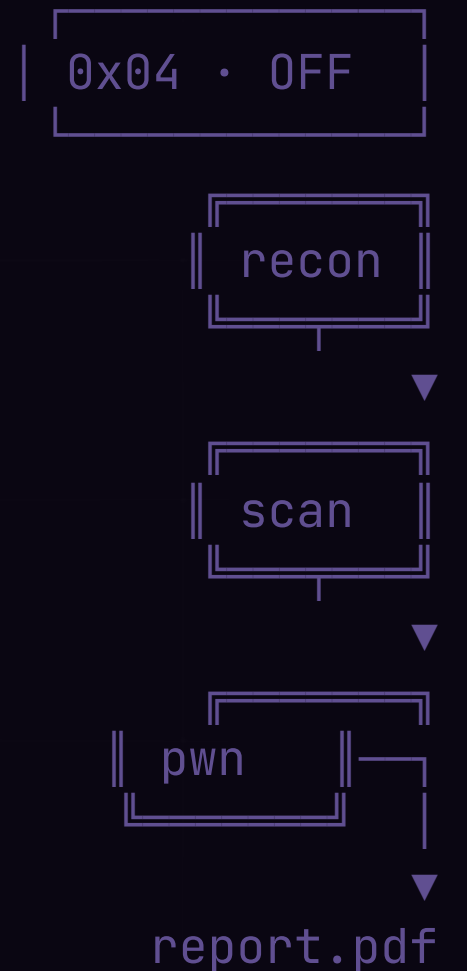
Ethical Hacking y Pentesting

Pensar como un atacante, con permiso y método. Las fases, los sombreros, los marcos (PTES, OWASP, MITRE ATT&CK) y por qué un buen informe vale más que un exploit.

• 17 diapositivas

~25 min

Nivel • Iniciación + Práctica



Qué vamos a ver

/01	¿Qué es ethical hacking?	definición
/02	Sombreros: white, grey, black	ética
/03	Pentest vs auditoría vs bug bounty	tipos de servicio
/04	Modalidades: black / grey / white box	información previa
/05	Las 5 fases del pentest	PTES
/06	Reconocimiento y enumeración	2 slides
/07	Explotación y post-explotación	control
/08	Marcos: PTES · OWASP · NIST · OSSTMM	estándares
/09	MITRE ATT&CK	tácticas y técnicas
/10	Lab · enumeración y explotación inicial	manos a la obra

03 · DEFINICIÓN

El **ethical hacking** es la práctica autorizada de atacar sistemas propios o de terceros con permiso explícito, para encontrar y reportar vulnerabilidades antes de que las usen los atacantes reales.

Síntesis a partir de PTES – Penetration Testing Execution Standard [1]

scope · qué se puede tocar y qué no

RoE · Rules of Engagement firmadas

NDA · confidencialidad de los hallazgos

report · entregable de valor

Los tres sombreros

W

White hat

// ethical hacker

Investiga con permiso explícito de la organización. Sigue una metodología, firma NDA y entrega un informe con remediaciones.

✓ legal · cobra honorario

G

Grey hat

// zona gris

Encuentra fallos sin permiso pero los reporta de forma responsable. Sigue siendo ilegal, aunque la intención no sea maliciosa.

~ ilegalidad · riesgo penal

B

Black hat

// adversary

Ataca por lucro, ideología o servicio. Vende exploits, despliega ransomware, exfiltra datos. Sus técnicas son las que estudiamos para defendernos.

X ilegal · ciberdelito

No es lo mismo un pentest que una auditoría

Pentest Simulación de un atacante real con alcance limitado. Profundiza hasta demostrar impacto. Entrega informe con PoC y remediación.

Red Team Ejercicio completo y sigiloso simulando un APT durante semanas o meses. Evalúa también la detección y respuesta del Blue Team.

Auditoría Revisión sistemática contra un estándar (ISO 27001, ENS, PCI-DSS). Más amplia y menos profunda que un pentest.

Vuln. Assessment Escaneo automatizado con Nessus, Qualys, OpenVAS. Identifica vulnerabilidades conocidas pero no las explota.

Bug Bounty Programa abierto y continuo. Pagas por hallazgo validado. HackerOne, Bugcrowd, Intigriti, Hack the Pentagon (DoD).

Purple Team Red + Blue colaborando en tiempo real. El objetivo no es ganar, es mejorar la detección y respuesta de la organización.

Black / Grey / White box

El nivel de información que el cliente comparte con el equipo ofensivo define la modalidad del test.

// black box

Caja negra

El pentester arranca con la misma información que un atacante externo: nombre de la empresa y poco más. Maximiza realismo, alarga la fase de reconocimiento.

simula · atacante externo

// grey box

Caja gris

Recibe información parcial: credenciales de usuario estándar, diagramas de red, alcance de las APIs. La modalidad más común en pentests de aplicación.

simula · insider o usuario

// white box

Caja blanca

Acceso total: código fuente, arquitectura, credenciales privilegiadas. Permite la auditoría más exhaustiva y eficiente. Habitual antes de pasar a producción.

simula · revisión interna

Las 5 fases (PTES)

/01

Reconocimiento

Recopilar información pública del objetivo sin tocarlo: dominios, empleados, tecnologías.

OSINT · whois ·
theHarvester

/02

Enumeración

Interacción activa: descubrir hosts, puertos, servicios y versiones expuestas.

nmap · masscan ·
gobuster

/03

Explotación

Aprovechar una vulnerabilidad para obtener acceso. Aquí es donde se demuestra el impacto.

metasploit · sqlmap
· burp

/04

Post-explotación

Escalar privilegios, moverse lateralmente, persistir y demostrar alcance real del compromiso.

mimikatz ·
bloodhound ·
linpeas

/05

Reporting

Documentar hallazgos con evidencia, riesgo, impacto y recomendación priorizada.

CVSS v3.1 · dradis
· markdown

▲ El informe es el verdadero entregable. Sin un buen reporte el pentest no aporta valor al cliente.

Reconocimiento pasivo (OSINT)

Qué buscar // huella digital

dominios	whois · crt.sh (certs Transparency) · subfinder
tecnologías	wappalyzer · builtwith · cabeceras HTTP
empleados	LinkedIn · theHarvester · hunter.io
leaks	HIBP · DeHashed · paste sites · GitHub dorks
infra expuesta	shodan.io · censys.io · zoomeye

Reglas de oro // opsec

- OSINT = información pública. No estás tocando los sistemas del cliente.
- Confirma alcance: a veces dominios sí, redes sociales no.
- Documenta cada fuente: el informe necesita trazabilidad.
- Distingue passive (no contacto) de active (consultas, fingerprinting).

Enumeración activa

Aquí ya generas tráfico contra el objetivo. Necesitas permiso firmado y, normalmente, ventana de mantenimiento.

nmap

El estándar de facto. Descubre hosts, puertos, servicios, versiones y vulnerabilidades con NSE scripts. -sV -sC -p-.

masscan

Para escanear Internet entero. Mucho más rápido que nmap pero menos fiable. Útil en rangos grandes.

gobuster

Descubrir rutas y subdominios. Fuerza bruta con diccionarios (SecLists). Encuentra /admin, /api/v2.

/ ffuf

enum4linux

Enumera SMB/Samba. Usuarios, grupos, shares, políticas. Lo primero contra un Windows.

ng

nuclei

Detección de vulns conocidas con plantillas YAML. Comunidad muy activa.

burp

suite

Proxy interceptador para aplicaciones web. Estándar en pentest de webapps.

Explotación y post-explotación

Explotación // gain access		Post-explotación // keep access	
objetivo	Convertir una vulnerabilidad en acceso (shell, sesión, token).	priv esc	linpeas / winpeas · binarios SUID · servicios mal configurados.
cómo	Metasploit Framework · searchsploit · exploits 1-day o 0-day.	credenciales	mimikatz · LSASS dump · DCSync.
web	SQLi, XSS, IDOR, RCE, deserialization · OWASP Top 10.	lateral	BloodHound + AD path · pass-the-hash, pass-the-ticket.
credenciales	hydra , medusa , crackmapexec · password spraying.	persistencia	Cron, systemd timers, scheduled tasks, run keys, golden ticket.

Marcos y estándares

Trabajar contra un marco da consistencia, repetibilidad y vocabulario común con el cliente.

PTES

// pentest-standard.org

Penetration Testing Execution Standard. Las 7 fases canónicas y plantillas de informe.

OWASP WSTG

// owasp.org

Web Security Testing Guide v4.2. Procedimientos por categoría para auditar webapps.

OSSTMM 3 // isecom.org

Open Source Security Testing Methodology. Métricas y mediciones objetivas (RAVs).

NIST SP 800-115 // csrc.nist.gov

Technical Guide to Information Security Testing and Assessment. Referencia gubernamental.

ISSAF // [OISSG](https://oissg.org)

Information Systems Security Assessment Framework. Énfasis en evaluación corporativa.

CVSS v3.1 // [FIRST.org](https://first.org)

Common Vulnerability Scoring System. Puntuar y comparar la severidad de cada hallazgo.

MITRE ATT&CK

Matriz pública de **tácticas** (el por qué) y **técnicas** (el cómo) observadas en el mundo real. El idioma compartido entre Red y Blue Team.

RECON	INITIAL ACCESS	EXECUTION	PERSISTENCE	PRIV ESC	LATERAL MOV	EXFILTRATION
Active scan	Spearphishing	PowerShell	Run keys	SUID binaries	PsExec / SSH	Over HTTPS
Phishing info	Valid accts	Cmd / Bash	systemd unit	Token theft	Pass-the-hash	DNS tunnel
Search engines	Public-facing	Scheduled task	Acct creation	DLL hijack	RDP hijack	Cloud storage

▲ Cada celda es una técnica con un código **Txxxx**. Sirve para mapear tu pentest, los detectores del SOC y los IOC de un APT al mismo vocabulario.

Reporting · qué espera el cliente

[01]Resumen ejecutivo · 1 página · sin jerga · qué se hizo, qué se encontró, qué hay que hacer.	C-level
[02]Alcance y reglas · qué se probó, qué quedó fuera, ventanas y limitaciones (RoE).	scope
[03]Metodología · marcos seguidos (PTES, OWASP, ATT&CK) para que sea reproducible.	method
[04]Hallazgos · cada uno con descripción, evidencia, severidad CVSS y reproducción.	findings
[05]Remediación priorizada · acciones concretas, no "endurezca su sistema".	fix
[06]Anexos · logs, scripts, capturas, listado completo de hosts y puertos.	data

Marco legal • España y UE

Sin un contrato firmado y un alcance claro, lo que hacemos pasa de ethical hacking a delito en cuestión de minutos.

CP 197 Descubrimiento y revelación de secretos. Penal el acceso a datos personales sin autorización.

CP 197 bis Intrusismo informático. Acceso ilegítimo a un sistema • 6 meses a 2 años de prisión.

CP 264 Daños informáticos. Borrar, alterar o inutilizar datos o programas ajenos.

RGPD / LOPDGDD Datos personales. Lo que recopiles en un pentest cae bajo el reglamento. Anonimiza y borra.

NIS2 Directiva UE 2022/2555. Obliga a entidades esenciales a realizar tests de seguridad regulares.

Contrato + RoE Antes de cualquier comando. Autoriza por escrito qué, cómo, cuándo y con qué intensidad.

Enumeración + explotación contra Metasploitable2

// attacker
Kali Linux
172.18.0.2

docker bridge ·
172.18.0.0/16

// target
Metasploitable2
172.18.0.3

LAS 3 FASES QUE TOCARÁS

- › Recon/enum · nmap a fondo con NSE scripts.
- › Explotación · Metasploit contra vsftpd 2.3.4 (backdoor conocido).
- › Reporting · CVE, CVSS, evidencia y remediación.

```
●●● kali@kali · ~/lab-04 · bash
```

[01] Enumera puertos, servicios y versiones:

```
$ nmap -sV -sC -p- -oN lab04.txt X.X.X.X
```

[02] Identifica una versión vulnerable, p.ej. vsftpd 2.3.4:

```
$ searchsploit vsftpd 2.3.4
```

[03] Explótalo con Metasploit:

```
$ msfconsole
```

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf6 > set RHOSTS X.X.X.X && run
```

6 ideas para llevarte

- /01 Ethical hacking = atacar **con permiso escrito**. Sin RoE firmado, no se toca nada.
- /02 Sombreros: **white legal**, **grey zona gris**, **black ilegal**. La diferencia es el permiso.
- /03 Pentest ≠ auditoría ≠ red team ≠ bug bounty. Cada uno tiene su **alcance y profundidad**.
- /04 5 fases PTES: **recon** → **enum** → **exploit** → **post** → **report**. El informe es el entregable de valor.
- /05 Marcos: **PTES**, **OWASP**, **OSSTMM**, **NIST 800-115**, **CVSS**. Dan consistencia y vocabulario común.
- /06 **MITRE ATT&CK** es el idioma común entre red y blue team. Mapea cada técnica a un código Txxxx.

SIGUIENTE · TEMA 05

Análisis de Vulnerabilidades

El paso previo a explotar. Escáneres, CVE, CVSS, NVD, gestión de vulnerabilidades en empresa y diferencias con un pentest.

→ continúa en el siguiente vídeo

Para profundizar

Marcos oficiales, estándares y la base legal en España y UE.

[1]	PTES	Penetration Testing Execution Standard · pentest-standard.org
[2]	OWASP	Web Security Testing Guide v4.2 · Top 10 2021 · owasp.org
[3]	NIST SP 800-115	<i>Technical Guide to Information Security Testing and Assessment</i> · csrc.nist.gov
[4]	MITRE ATT&CK	Enterprise Matrix v15 · attack.mitre.org
[5]	CVSS / FIRST	Common Vulnerability Scoring System v3.1 · first.org/cvss
[6]	Marco legal	Código Penal español arts. 197-264 · RGPD UE 2016/679 · Directiva NIS2 UE 2022/2555